



PRODUCT FILE · PAT-APP-01

The File Room

A client app for Pivot Aide Tax

Secure document exchange, IRS-compliant signing, the prepared return, questions answered where the documents are, the service catalogue, and payment — on the web and on iOS and Android. It does not compute tax.

10	3	9	3 yr
SCREENS DESIGNED	PHASES TO FULL RELEASE	SAFEGUARDS RULE ELEMENTS YOU TAKE ON	SIGNATURE EVIDENCE YOU MUST RETAIN

PREPARED FOR **Tonye George** · Pivot Aide Tax

DECISION TAKEN Design the **custom app** — web app plus native iOS and Android

EXCLUDED BY DESIGN Tax computation, automated advice, anything that replaces a preparer's judgement

COMPANION FILE Clickable prototype — all ten screens, phone and web

What you are choosing, and what it costs

You asked for a custom app rather than a configured platform. That is a defensible choice, but it is an expensive one, and the reason it is expensive is worth stating on the first page rather than the last.

Five products already do most of what you described — TaxDome, Canopy, Liscio, SafeSend and Karbon. They are licensed per seat, they carry IRS-compliant signing, and the vendor absorbs the security engineering. Below is what each path actually costs a firm of roughly six staff and four hundred clients.

LICENSED PLATFORM — PUBLISHED 2026 PRICING

TaxDome	Pro tier, unlimited seats. Unlimited e-signature. IRS Form 8879-compliant KBA at \$1.00 per signer attempt. White-label client app quoted separately.	\$1,000 PER SEAT / YR
Canopy	Standard \$74 to Premium \$149 per user per month, billed annually. KBA credits \$1.25 each.	\$888 PER USER / YR, STANDARD
Liscio	\$19 / \$49 / \$99 per user per month. Tax Team tier bundles 100 signatures per user. No published KBA claim.	\$588 PER USER / YR, PLATFORM
SafeSend	Priced per return, not per seat. Purpose-built for 8879 signing. Pricing not published — sales call required.	n/p QUOTE REQUIRED

CUSTOM BUILD — THE PATH CHOSEN

Year one	Web portal, then native iOS and Android. Design, build, security programme, first penetration test.	\$175k–\$400k RANGE, NOT A QUOTE
Every year after	Hosting, identity, scanning, monitoring, e-signature licences, annual penetration test, semi-annual vulnerability scans, maintenance at 15–20% of build.	\$55k–\$119k PER YEAR

THE NUMBER THAT MATTERS

Spread over three years, the custom path runs somewhere between **\$280 and \$630 per client per year** at four hundred clients. TaxDome at Pro, with KBA, runs about **\$17 per client per year**. That is a difference of seventeen to thirty-seven times, and no amount of design quality closes it — which is why **Exhibit J** argues the only version of this that pencils is one where the app is a product you can license to other firms, not an internal tool.

The rest of this file takes the decision as made and answers the real question: what has to be true for it to work.

Seven capabilities. One hard exclusion. The exclusion is the more important half.

01 • EXCHANGE

Secure document upload

Named requests, not “send everything.” Camera capture on the phone, drag-and-drop on the web. Malware scanned on arrival, encrypted at rest, every access logged.

Build
own

02 • REGULATED

Signing, including Form 8879

Identity verification, the signature, and the evidence record the IRS requires you to keep. This is the one component to license rather than write.

Buy
embed a vendor

03 • DELIVERY

The prepared return

A read-only copy of what the firm prepared, with a plain-language note on what changed since last year. Read, ask, approve, sign.

Build
own

04 • DIALOGUE

Questions and answers

Threaded messaging attached to the file, so a question about a document sits beside the document. Replaces email, which is where taxpayer data goes to leak.

Build
own

05 • ATTENTION

Updates that are actually about you

Stage changes, deadlines on your file, and rule changes that move your number. Push and email. Never a newsletter blast dressed as an alert.

Build
own

06 • COMMERCE

The service catalogue

The published lineup, priced as the site prices it, with The Standing File at the top. Add a service, accept a scope, and the engagement letter goes out.

Build
own

07 • MONEY

Payment

Bank transfer as the default because it is cheaper, card as the alternative. Card details never touch your systems.

Buy
hosted processor

THE EXCLUSION, STATED PLAINLY

The app **does not compute tax** and does not generate advice. It moves documents, signatures, answers and money; every number a client sees was put there by a person at the firm. That is not a limitation to apologise for — it keeps the app clear of the software-that-gives-tax-advice problem, and it lets you say honestly that the app never replaces the preparer.

Each of these is built in the companion prototype. Screen numbers match.

- 01 Sign in**
Email and password, then a second factor. Passkey and Face ID on the phone. The second step is not a product choice — multi-factor authentication is mandatory for anyone reaching customer information under the Safeguards Rule.
- 02 Your file**
The whole thesis on one screen: *your file is open*, this is what stage it is at, and these two things are waiting on you. A six-step progress spine from engagement letter to IRS acceptance. Everything else on the home screen is subordinate to those two things.
- 03 Documents**
Grouped by status — needed, in review, received — and every missing item named specifically. “1099-MISC from Keystone Property Group” gets answered. “Upload your documents” does not.
- 04 Sign**
The regulated screen. Read the form, pass the identity check, sign. Three attempts, then a graceful fall back to a handwritten signature. Detailed in **Exhibit D**.
- 05 Your return**
Refund or balance, the effective rate, and — the part clients actually read — *three things that changed from last year*, in sentences. Then approve, ask, or download.
- 06 Messages**
One thread per file, with quick-question chips for the five things everyone asks. Uncle Pat appears here as the automatic voice — deadline reminders and rule notes — while the preparer answers as herself.
- 07 Services**
The published lineup at the published prices, plus the free notice read. This is the screen that turns a filing client into a planning client.
- 08 Billing**
Itemised invoice, bank transfer default, card with the fee shown before confirmation. Payment history stays visible.
- 09 Updates**
File events and the rule changes that touch this client, with per-category notification controls the client actually owns.
- 10 Firm view**
The half nobody demos: who is waiting, who has not signed, whose KBA failed, what is due today. Without this the app makes the client’s life better and the firm’s worse.

Everything else in this app is ordinary software. Form 8879 is not. Get this component wrong and returns are not validly authorised.

IRS Publication 1345 governs electronic signatures on e-file authorisation forms. When the taxpayer is **remote** rather than in front of you, the requirements are specific:

1

Identity verification every time

Knowledge-based authentication — multiple-choice questions generated from the taxpayer's credit file. Not a credit check, and it does not affect their credit, but it does require a consumer-reporting data source.

2

Three attempts, then stop

Fail three times and the ERO must obtain a handwritten signature instead. The app has to handle that failure path as a normal outcome, not an error state — for some clients KBA simply never works.

3

A tamper-proof evidence record

The signed form image, date and time, the taxpayer's IP address, the login used, the identity-verification result, and the signature method — retained three years from the later of the return due date or the date the IRS received it.

4

In person is different

A taxpayer signing in your office needs a visual ID check, not KBA. So does a returning client in a multi-year relationship who signed in person previously. The app has to know which path a given signer is on.

RECOMMENDATION — BUY THIS ONE COMPONENT

Of the general e-signature APIs, **DocuSign** is the one that both markets 8879/Pub 1345 compliance explicitly and publishes a per-transaction identity-verification price: **\$2.40 per attempt**, on top of \$30–\$45 per user per month. Dropbox Sign's API is cheaper per envelope but does not publish a KBA price or market this use case. **SafeSend** is purpose-built for 8879 signing and could sit behind your app as the signing engine, though its pricing is gated behind a sales call.

Writing your own KBA is not a cost saving. It means contracting with a consumer-reporting agency, building question generation and scoring, and defending the evidence record if a return's authorisation is ever challenged. Licence it.

Running your own portal makes you the custodian

A tax preparer is a “financial institution” under the FTC Safeguards Rule. That is already true today. Holding client documents on your own infrastructure makes it considerably more expensive to satisfy.

THE NINE ELEMENTS • 16 CFR 314.4

- A named Qualified Individual accountable for the programme
- A written risk assessment, reassessed periodically
- Safeguards: access control, data inventory, encryption in transit and at rest, secure development, MFA, secure disposal, change management, logging
- Annual penetration testing and vulnerability scans every six months, plus after material changes
- Staff security training, kept current
- Service-provider oversight — selection, contract terms, reassessment
- Keeping the programme current
- A written incident response plan
- An annual written report to the senior officer

AND THEN

- Breach notice to the FTC within 30 days where 500 or more consumers' unencrypted information was acquired — in force since 13 May 2024
- State breach law in every affected resident's state. You file in all fifty; one incident can trigger fifty different clocks. Maryland gives 45 days and requires notice to the Attorney General first; the District requires 18 months of identity protection where taxpayer identifiers are involved
- Disposal of customer information no later than two years after last use, unless retention is required
- A written information security plan — IRS Publication 4557 requires it, Publication 5708 is the template
- IRC §7216 on disclosure of return information: criminal penalty up to \$1,000 and one year; civil penalty \$250 per disclosure to a \$10,000 annual cap, rising to \$1,000 and \$50,000 where identity theft is involved

ONE PIECE OF GOOD NEWS

A firm holding information on **fewer than 5,000 consumers** is exempt from four of these — the written risk assessment, the prescribed testing cadence, the incident response plan and the annual report. Count your consumer records: if you are under the line, say so in the security programme and revisit it annually, because it is a threshold you grow through rather than a permanent relief. Encryption, MFA, disposal and service-provider oversight apply either way.

Buying a platform does not remove any of this. It moves most of the technical burden onto a vendor you must still select, contract with and reassess — which is itself one of the nine elements.

How it is put together

One backend, three clients, four licensed services. Nothing exotic — the engineering risk here is not architectural, it is in the handling of regulated data.

WHAT YOU BUILD

API and data layer	Clients, engagements, tax years, document requests, documents, messages, invoices, events. Multi-tenant from day one even though there is one firm today — retrofitting tenancy is the expensive mistake.	core
Web client	Responsive, the same application on desktop and phone browser. Screens 01–09.	phase 1
Firm console	Screen 10. Assignment, request templates by return type, automatic chasing, the signature evidence archive, the audit log.	phase 1
iOS and Android	Native. Push, camera capture, biometric unlock. Same API.	phase 2

WHAT YOU LICENSE

Identity	Managed authentication with MFA. Auth0 is free to 25,000 monthly active users; AWS Cognito runs \$0.015–\$0.020 per monthly active user; Clerk is free to 50,000 then \$0.02.	<\$50 PER MONTH AT YOUR SCALE
E-signature + KBA	DocuSign, or SafeSend behind the app. See Exhibit D.	\$2.40 PER IDENTITY CHECK
Payments	Fully hosted checkout, so card data never reaches your servers. Stripe 2.9% + \$0.30 card, 0.8% ACH capped at \$5. CPACharge \$10/month, 2.99% + \$0.30, 1% ACH capped at \$10 — and it supports surcharging, which Stripe leaves you to build.	2.9% + \$0.30 CARD
Upload scanning	Malware scanning on every inbound file. From \$99 per month for 5,000 scans.	\$99 PER MONTH
Storage, logging	Encrypted object storage at \$0.023 per GB per month; centralised logging and alerting.	\$100–\$250 PER MONTH

THE PAYMENTS DECISION THAT CHANGES YOUR COMPLIANCE BURDEN

If the client is redirected to the processor's own hosted page, you sit in the lightest PCI category — roughly twenty-two requirements. If you embed card fields in your own page, even in an iframe, you move to the next category up: around **191 requirements**, essentially full PCI DSS. Redirect. It costs one extra screen transition and saves a compliance programme.

A build of this size takes long enough to cross a filing season. The first move is therefore not a build decision at all.

0

This season, on a licensed platform

Stand up TaxDome or Canopy now, at roughly \$6,000–\$9,000 for the year. It gives clients a portal and compliant signing for the coming season, it produces the workflow evidence your own product should be designed from, and it means the build is never on the critical path of a deadline. If the build stalls, the practice is unaffected.

1

Web app and firm console

Screens 01–10, responsive, on the web only. Licensed identity, licensed signing, hosted payments. This is the phase that carries almost all the value: a client on a phone browser can already upload, sign, read, ask and pay. Ends with the first penetration test and a written security programme.

Roughly \$90k–\$200k and four to seven months.

2

Native iOS and Android

What native actually buys: push notifications that arrive, camera capture that feels like a scanner, and biometric unlock. Everything else is the web app. Ship only once phase 1 is stable with real clients — app review cycles make a moving target expensive.

Roughly \$60k–\$150k for both platforms and three to five months.

3

The parts that make it a business

Engagement letters generated from an accepted scope, recurring billing for The Standing File and bookkeeping, the planning-calendar view that expresses the year-round positioning, and — if Exhibit J's argument lands — the multi-firm tenancy that turns this from overhead into a product.

SEQUENCING RULE

Do not start phase 2 before phase 1 has run one full filing season. Native apps are the most expensive place to discover that a workflow was wrong.

What it costs to run, every year, forever

Modelled at six staff and four hundred clients, with roughly six hundred signatures a year. Ranges are planning figures drawn from published rates, not quotes.

ANNUAL RUN RATE – CUSTOM BUILD

Hosting	Compute, database, backups	\$3,000
Storage	Encrypted object storage and versioning	\$200
Identity	Managed authentication with MFA	\$150
Upload scanning	Malware scanning, 5,000 files	\$1,200
Logging	Centralised logs, alerting, retention	\$1,200
E-signature	Six seats plus 600 identity checks at \$2.40	\$4,700
Vulnerability scans	Semi-annual, as the Safeguards Rule requires	\$3,600
Penetration test	Annual, web and mobile	\$18k–\$35k
App stores	Apple \$99 a year, Google \$25 once	\$124
Maintenance	15–20% of the \$150k–\$350k software build, the industry rule of thumb	\$23k–\$70k
Total	Before payment processing, which is a percentage of fees collected either way	\$55k–\$119k

THE SAME PRACTICE ON A LICENSED PLATFORM

TaxDome Pro	Six seats, unlimited signatures, 600 KBA attempts at \$1.00	\$6,600
-------------	---	---------

READ THIS LINE TWICE

The penetration test alone costs more each year than the entire platform licence. That is not an argument against building — it is the argument that building only makes sense if the thing you build earns revenue of its own.

You chose web plus native. Native is worth having, but it introduces two gatekeepers with opinions about financial apps.

WHAT NATIVE GENUINELY BUYS

- Push notifications that arrive. The single biggest reason clients respond faster — browser push on iOS is still unreliable
- Camera capture that behaves like a scanner — edge detection, multi-page, straightened output. This is how a W-2 gets uploaded from a kitchen table
- Face ID and Touch ID as the second factor, which removes most of the friction MFA otherwise adds
- Presence. An icon on the home screen is a year-round reminder that the file is open

WHAT IT COSTS YOU IN PROCESS

- Privacy disclosures on both stores, including a financial-data category, kept accurate as the app changes
- In-app account deletion is mandatory on both — with a documented exception for regulated retention, which your three-year signature records need
- Review cycles on every release. Fixes are not same-day
- Two more codebases to maintain, test and pay for in the annual penetration test
- Apple \$99 a year; Google \$25 once

OPEN QUESTION — CONFIRM BEFORE YOU BUILD THE PAYMENT SCREEN

Both stores exempt real-world services consumed outside the app from mandatory in-app purchase and its 15–30% commission. Apple's guideline covers “physical goods or services that will be consumed outside of the app”; Google's names physical services such as transport and gym memberships. Tax preparation reads squarely as such a service — but **neither store names professional services as a labelled exemption**, and the inference has never been tested for your app.

A 15–30% commission on tax-preparation fees would be catastrophic to the model. Confirm it in writing with both stores, or through app-review counsel, before phase 2 starts. If in doubt, phase 2 ships without in-app payment and links out.

As an internal tool, this app costs seventeen times the alternative at best. As a **product**, the same code has a market.

Exhibit H is uncomfortable on purpose. As a portal for one firm, a custom build is a large permanent cost centre bought to replace a \$6,600 subscription. No honest reading of those numbers says otherwise.

But there is a second reading. Everything in Exhibit F — multi-tenancy from day one, licensed signing, hosted payments, a firm console — describes a product that other small tax firms need and are currently paying \$800 to \$1,200 per seat per year for. Pivot Aide would be building against a market it is already inside, with a brand character nobody else has and a positioning — the file that stays open all year — that the incumbents do not articulate.

WHAT HAS TO BE TRUE

- Multi-tenant from the first commit, not retrofitted
- The firm console is treated as the product, not an afterthought
- Someone owns it as a product — roadmap, support, releases
- SOC 2 becomes a real objective, because firms will ask
- Ten to twenty paying firms at \$6,000 covers the run rate in Exhibit H

WHAT KILLS IT

- Building it single-tenant “for now”
- Writing your own KBA instead of licensing it
- Embedding card fields and inheriting full PCI scope
- Starting phase 2 before phase 1 survives a season
- Nobody at the firm owning the security programme by name

THE RECOMMENDATION, IN ONE SENTENCE

Run this season on a licensed platform, build phase 1 as a multi-tenant product rather than a private portal, and decide at the end of the first season whether you are running a tax firm with a good app or a tax firm with a software business — but build it so that the second answer stays available.

Nine open items. The first three block the build; the rest block launch.

01 Is this a product or a portal?

Exhibit J's question. It changes the data model on day one and cannot be deferred.

02 Who is the Qualified Individual?

The Safeguards Rule requires a named person accountable for the security programme. It can be you; it cannot be nobody.

03 Who builds it?

An agency, a contract team, or a hire. The cost ranges in this file assume US or nearshore agency rates — \$100 to \$149 an hour in the States, \$55 to \$120 nearshore.

04 Circular 230 representation rights — still open.

The same question that gates Audit & Resolution tiers 2 and 3 and The Standing File on the website. The app's services catalogue cannot list what the firm cannot perform.

05 Signing vendor.

DocuSign at \$2.40 per identity check, or SafeSend behind the app. SafeSend needs a call — they do not publish.

06 Do you want to surcharge card payments?

CPACharge supports it out of the box; Stripe leaves you to build and validate it per state. This decides the processor.

07 App store commission — confirmed in writing?

Exhibit I. Do not build in-app payment for phase 2 until this is answered.

08 The name.

"The File Room" is a working title chosen to sit beside The Standing File. It is yours to overrule.

09 Do we run phase 0?

A licensed platform this season, in parallel with the build. My recommendation is yes.

Checked 2 September 2026. Rules and prices change; re-verify before signing anything.

REGULATION

- **FTC Safeguards Rule** — 16 CFR Part 314, [ecfr.gov](https://www.ecfr.gov); FTC business guidance, “Safeguards Rule: What Your Business Needs to Know”
- **Breach notification** — 500 consumers, 30 days, effective 13 May 2024; FTC business blog, May 2024
- **Small-entity exemption** — 16 CFR §314.6, fewer than 5,000 consumers
- **WISP** — IRS Publication 4557; template at Publication 5708
- **Form 8879 e-signature** — IRS e-file signature authorisation FAQ and IRM 10.10.1; made permanent October 2023
- **§7216 and §6713** — 26 CFR 301.7216-1 and -2; Rev. Proc. 2013-14; 26 USC 6713
- **PCI DSS v4.0.1** — new requirements mandatory 31 March 2025; SAQ A versus SAQ A-EP scope
- **State breach law** — Md. Com. Law §14-3504; Va. Code §18.2-186.6; D.C. Code §28-3851

PRICES

- **TaxDome** — taxdome.com/pricing; KBA \$1.00 per signer, help centre
- **Canopy** — getcanopy.com/pricing; KBA credits \$1.25
- **Liscio** — liscio.me/pricing
- **Karbon** — karbonhq.com/pricing
- **SafeSend** — pricing not published; per-return figures circulating on G2 date from October 2024 and should not be budgeted from
- **DocuSign** — ecom.docusign.com plans and pricing; ID verification \$2.40
- **Stripe** — stripe.com/pricing
- **CPACharge** — cpacharge.com/pricing
- **Auth0, Cognito, Clerk** — each vendor's own pricing page
- **Penetration testing** — published 2026 industry ranges, Blaze Infosec and Invicti
- **Developer rates** — Clutch 2026 US web rates; Netguru 2026 mobile rates
- **App stores** — developer.apple.com/programs; Play Console help

STATED AS UNCERTAIN

Three figures in this file rest on secondary sources and are flagged rather than relied on: SafeSend's per-return pricing, the semi-annual vulnerability-scanning cost, and the 15–20% maintenance rule of thumb. The app-store commission question in Exhibit I is an inference from policy language, not a confirmed carve-out, and is the single item in this file most worth confirming before money is spent.